

# 當 AI 開始呼叫 API： 企業正面臨的新攻擊面

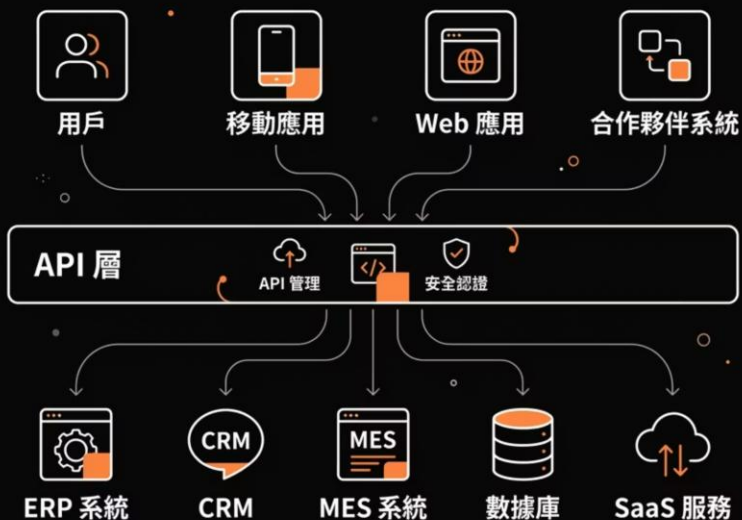
Mika Chan, 詹凱富

Cloud Architect, Radware API

# API 是企業服務的共同介面

在數位轉型的浪潮中，**API 始終扮演著企業系統整合的核心角色**。

無論是行動應用、Web 服務、合作夥伴系統，還是人類使用者，所有外部互動都必須穿越同一道門：**API Layer**。



## Mobile Apps

行動應用即時呼叫後端 API

## SaaS & Cloud Native

雲端服務間大量 API 串接

## Partner Integration

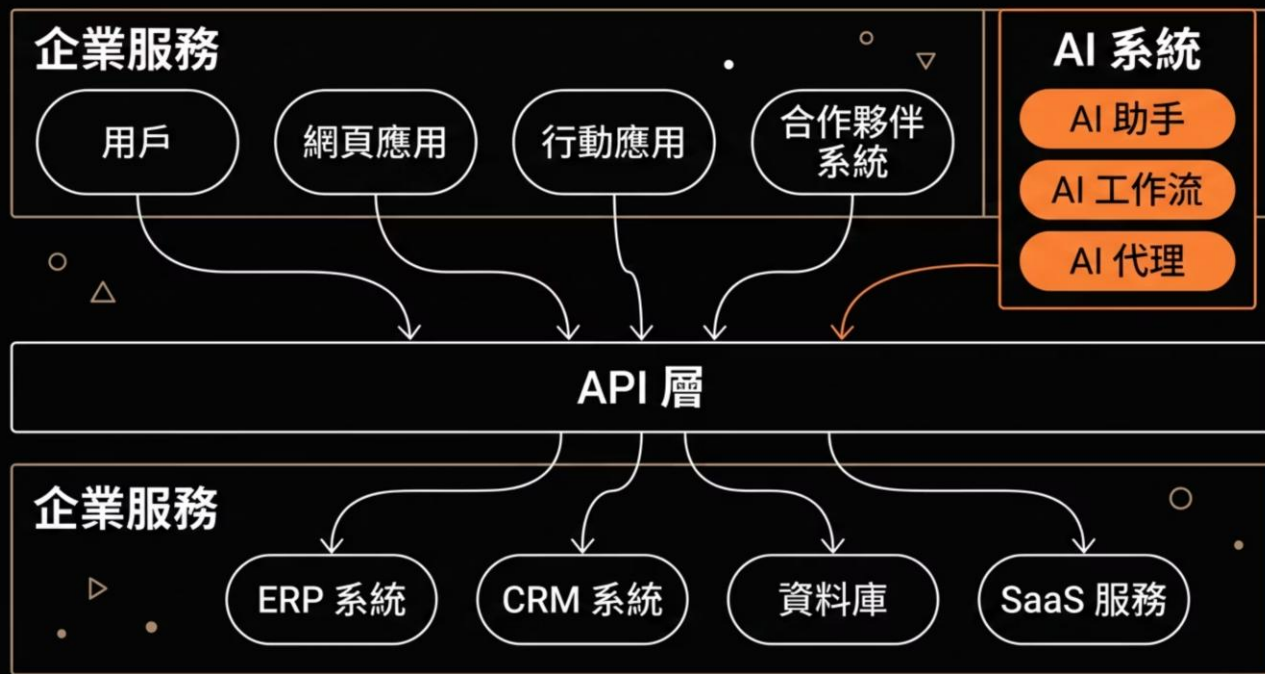
合作夥伴透過 API 存取核心資料

## AI Platforms & LLM

LLM 應用頻繁呼叫內部 API

# AI 加入之後

當 AI 進入企業生態系，架構圖上多了幾個新的消費者：AI Assistant、AI Workflow、AI Agent。但 API Layer 本身並沒有改變。



真正改變的是：企業 API 開始面對大量 Machine Consumers，自動化、高頻率、自主決策的 AI 系統成為新的主要呼叫方。

# AI 正在改變企業服務流量模型

## 企業 AI 導入浪潮

未來三年，企業將大規模部署各類 AI Agent 與自動化工作流程。這些系統擁有真實的 API 存取權限，卻往往**缺乏對應的安全管控機制**。



### AI Assistant

企業內部知識查詢與任務執行



### AI Workflow

跨系統自動化業務流程



### MCP Integration

Model Context Protocol 深度整合



### Autonomous Agents

自主決策、自主執行的 AI 系統

## AI Agent 的安全風險

這些 Agent 在執行任務時，會自主呼叫 API、存取敏感資料並執行關鍵操作——每一個動作都可能成為攻擊向量。

### 會呼叫 API

自主發起大量 API 請求，難以追蹤

### 會存取資料

可能存取超出必要範圍的敏感資訊

### 會執行動作

觸發真實業務操作，造成實質損害



**Security 必須開始保護：AI-to-API Communication**

# AI 在企業中的兩種角色

理解 AI 與 API 的關係，需要區分兩個截然不同的面向：

AI 是消費者還是服務提供者？這兩種角色對企業架構設計有著根本性的不同影響。



## AI Consumer

AI 使用 API 存取企業服務

在這個角色中，AI 系統作為 API 的呼叫方，使用服務來完成任務。

- Copilot — 輔助員工決策
- AI Agent — 自主執行流程
- Workflow — 自動化串接
- MCP — 標準化工具存取



## AI Service

企業透過 API 對外提供 AI 能力

在這個角色中，企業將 AI 功能封裝為 API 服務，供內外部系統調用。

- LLM API — 語言模型推論
- Chatbot API — 對話服務
- AI Gateway — 統一 AI 入口
- RAG Service — 知識增強檢索



多數企業在 AI 轉型過程中，兩種角色會同時存在，需要在 API 架構中統一規劃治理策略。

# AI 帶來的新型態攻擊模式

## AI + API 威脅矩陣

AI 技術不只提升防禦能力，也正在被攻擊者武器化，**大幅降低高複雜度攻擊的門檻**。

### Automated Reconnaissance

AI 自動探測 API 結構與弱點

### AI-driven Credential Abuse

智能化帳密攻擊，規避偵測

### Intelligent Bot Attacks

能模擬人類行為的新世代 Bot

### API Scraping

大規模自動化資料竊取

## 進階威脅向量

### Business Logic Abuse

利用 AI 分析並濫用商業邏輯漏洞

### AI Agent Misuse

授權 Agent 超出預期執行危險操作

### Token Abuse

竊取並重放 API Token

### LLM Backend Exposure

透過 LLM 接口直接觸及後端 API



AI 不只提升防禦能力，也正在大幅提升攻擊能力。



# 從 Consumer & Service 角度來看: 需要全新的防護模型

面對 AI 驅動的威脅，企業需要的不是修補舊有工具，而是**從根本重新定義 Security 的思維方式**——



## API/Agent Discovery

自動發現並盤點所有 API/Agent，  
包含 Shadow 與 Zombie API/Agent



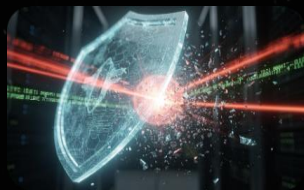
## 行為分析機制

建立行為基準線，  
即時偵測異常 呼叫模式



## API/Agent 態勢管理

持續評估風險暴露面，  
建立治理政策



## 即時防護能力

即時阻擋惡意請求，  
不依賴靜態規則



## Bot 感知能力

識別並區分合法自動化  
與惡意 Bot 流量

**Security 必須開始理解 API/Agent 的「行為」**

# Radware AI-Driven 防護框架



## Behavioral Protection

執行前進行意圖驗證



## Secure Access

僅限授權代理存取系統



## AI-Aware DLP

專為 AI 互動量身定制，保護提示和回應中的敏感訊息



## AI Guardrails

持續掃描並識別環境中的代理



## API/Agent & Tool Discovery

揭示盲點；監控所有API/Agent活動和資料流



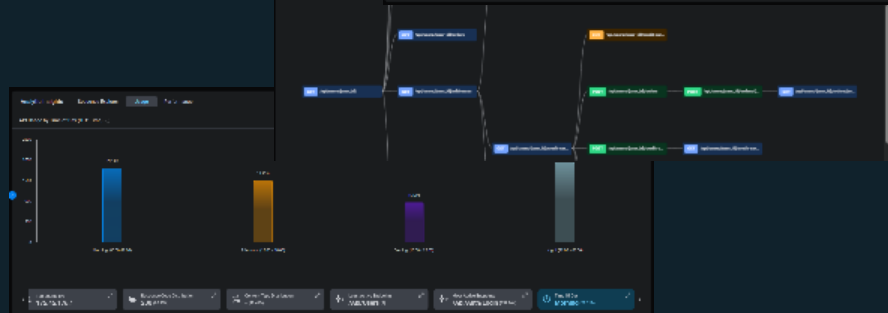
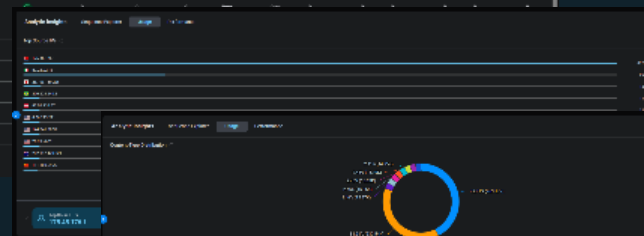
# AI-Driven API分析

不依賴靜態規則或文件匯入，而是**持續學習 API 的正常行為模式**，自動識別任何偏離基準的異常活動。

- API 探索與結構文件
- API 目錄統計
- 商業邏輯流程視覺化
- 效能統計 (Latency/RPS/Query Size..etc)
- 使用量統計(Content distribution..etc)



| Method | Path                     | Last Modified | Last Deployed | Last Status | Status Code | API Name                | API Type |
|--------|--------------------------|---------------|---------------|-------------|-------------|-------------------------|----------|
| GET    | /api/v1/users            | 2023-10-10    | 2023-10-10    | 200         | 200         | api/v1/users            | GET      |
| POST   | /api/v1/users            | 2023-10-10    | 2023-10-10    | 200         | 200         | api/v1/users            | POST     |
| GET    | /api/v1/users/{id}       | 2023-10-10    | 2023-10-10    | 200         | 200         | api/v1/users/{id}       | GET      |
| POST   | /api/v1/users/{id}       | 2023-10-10    | 2023-10-10    | 200         | 200         | api/v1/users/{id}       | POST     |
| DELETE | /api/v1/users/{id}       | 2023-10-10    | 2023-10-10    | 200         | 200         | api/v1/users/{id}       | DELETE   |
| PUT    | /api/v1/users/{id}       | 2023-10-10    | 2023-10-10    | 200         | 200         | api/v1/users/{id}       | PUT      |
| GET    | /api/v1/users/{id}/posts | 2023-10-10    | 2023-10-10    | 200         | 200         | api/v1/users/{id}/posts | GET      |
| POST   | /api/v1/users/{id}/posts | 2023-10-10    | 2023-10-10    | 200         | 200         | api/v1/users/{id}/posts | POST     |
| DELETE | /api/v1/users/{id}/posts | 2023-10-10    | 2023-10-10    | 200         | 200         | api/v1/users/{id}/posts | DELETE   |
| PUT    | /api/v1/users/{id}/posts | 2023-10-10    | 2023-10-10    | 200         | 200         | api/v1/users/{id}/posts | PUT      |



# API 探勘: API Security的基石



## 為什麼重要?

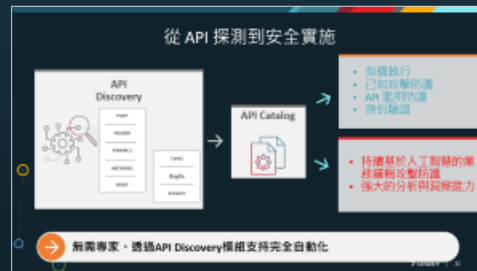


## 作用是甚麼?

- 從真實流量中發現 API
- 識別端點、參數...
- 追蹤隨時間的變化
- 顯示 shadow / zombie APIs



## 如何的運作?



# API 缺乏可見性的問題



## 未知的 APIs

API 的建立速度遠超過  
文件編寫速度



## 一致性的檢查

規範僵化，無法更新。  
並非安全問題



## Shadow / Zombie APIs

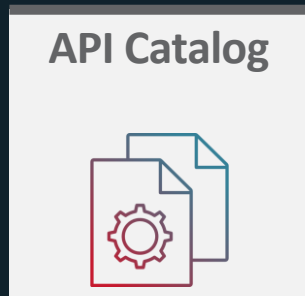
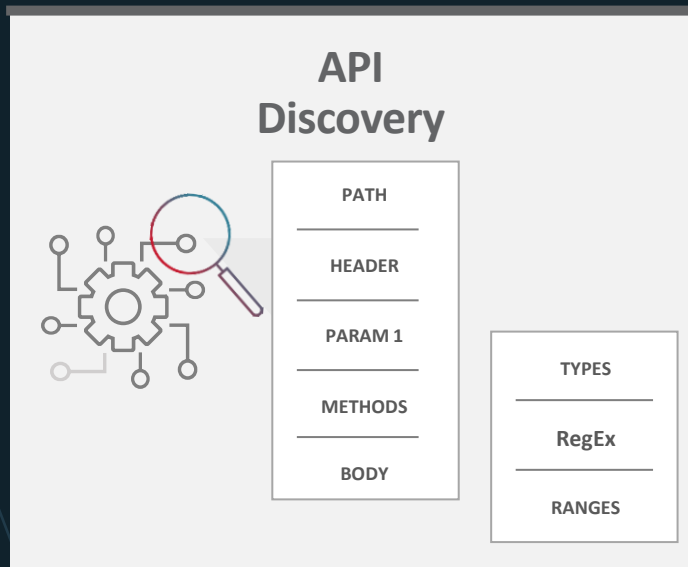
失控的徵兆，而不僅  
僅是技術異常的問題



## 缺乏深度監控

API 是否被使用？是理  
論風險還是實際風  
險？

# 從 API 探測到安全實施



- 架構執行
- 已知攻擊防護
- API 濫用防護
- 身份驗證

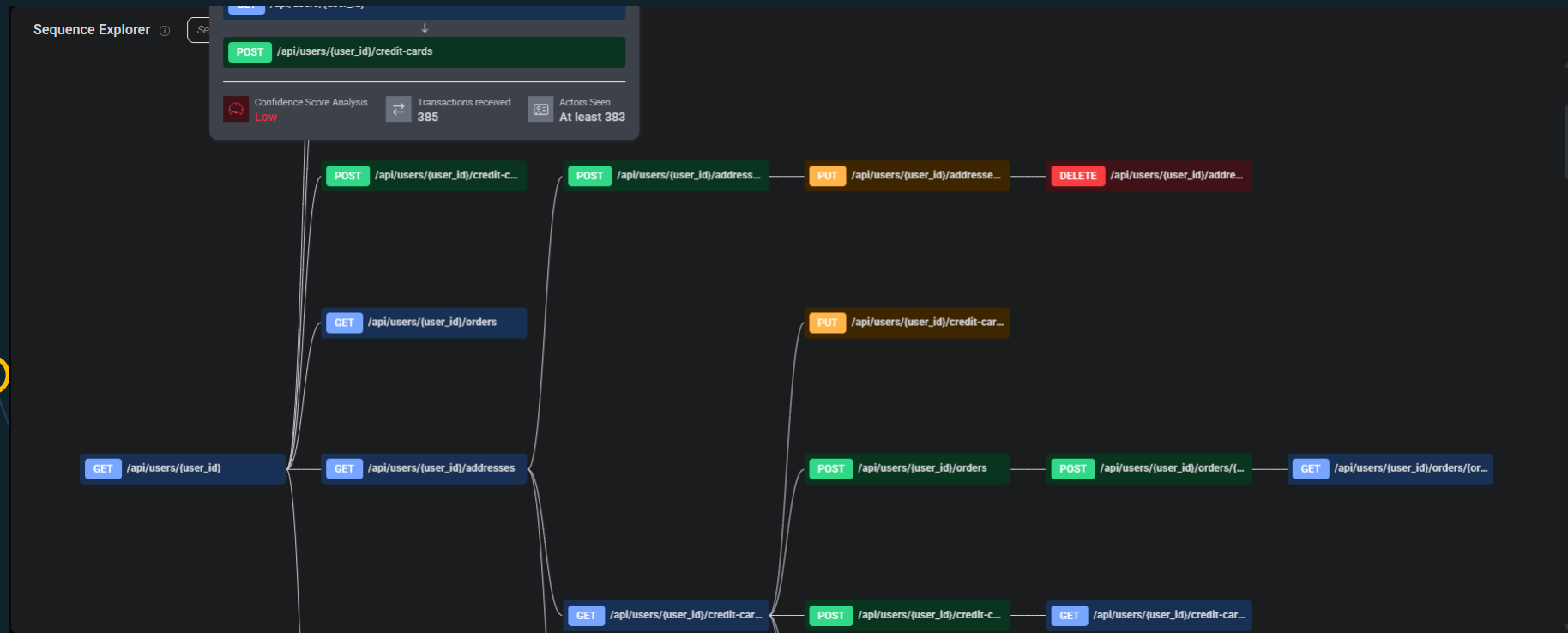


- 持續基於人工智慧的業務邏輯攻擊防護
- 強大的分析與洞察能力



無需專家。透過API Discovery模組支持完全自動化

# 商業邏輯流程視覺化





# 除了了解AI Agent做了哪些API行為以外，也要了解AI Agent呼叫那些工具以及狀態



**Agent Tools Discovery:** 持續掃描並識別環境中的代理。



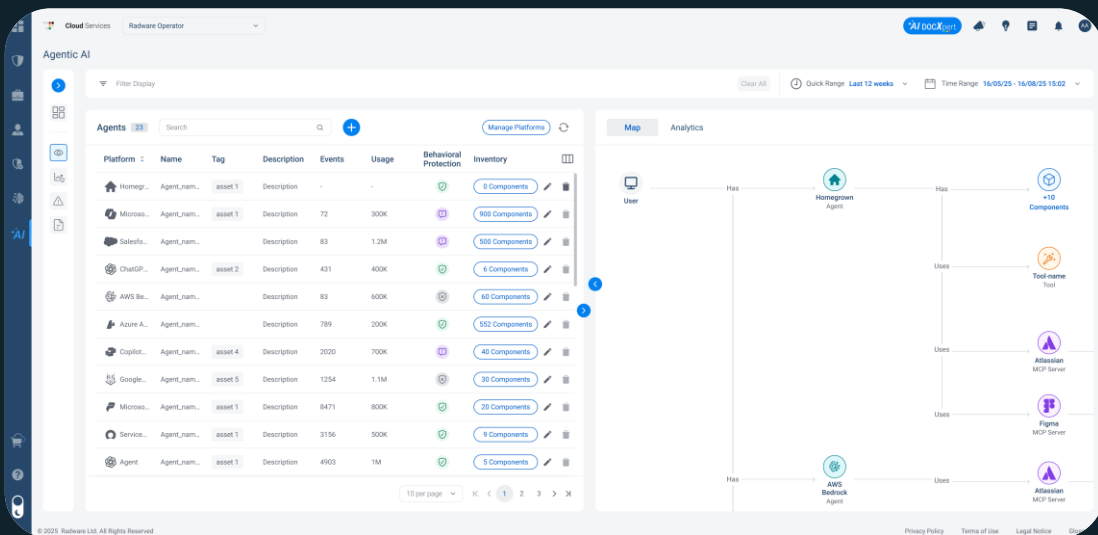
**Agent Relationship Mapping:** 持續可視化應用程式內的代理連接，以了解依賴關係和流量。



**Agent Behavior Analytics:** 追蹤長期代理活動，以發現使用趨勢、異常情況和效能變化。

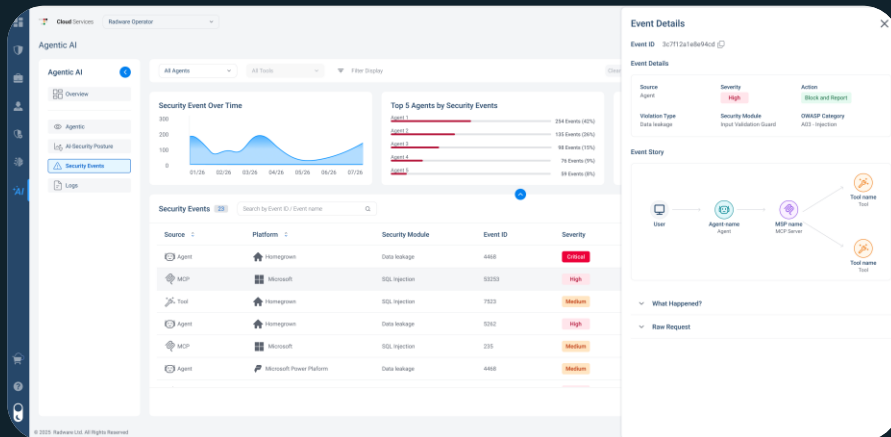
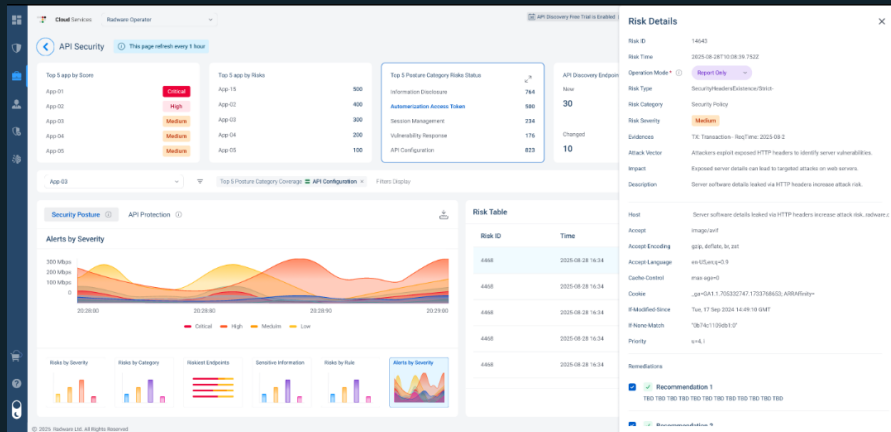


**Rich Agent Metadata:** 能夠查看代理配置、使用情況和工具。



# 即時偵測、預防和應對基於API/AI Agent 的威脅

- **API Security**: 針對惡意API存取行為進行防護。
- **LLM Guards**: 針對快速注入、越獄和不安全輸出的防護措施。
- **Behavior Data leakage prevention**: 即時時間監控代理操作，偵測並緩解惡意活動。
- **MCP Tool Control**: 允許/阻止每個代理程式使用的工具或是API Call。
- **Security Event**: 針對每次違規偵測，提供包含視覺化安全分析和對應的完整攻擊事件報告。



# Radware 對於 API 執行期的防護功能

## 認證

Token  
授權管控

用戶端憑證

## API 濫用 緩解

使用量限制  
(REST)

請求限制  
(GraphQL)

全域限速

## 負向防禦

惡意內容  
防護

資料  
洩漏預防

API 機器人  
防護

## 正向防禦

GraphQL &  
REST

架構驗證  
Documented &  
Undocumented

商業邏輯  
防護

## 洪水攻擊

API L7 DDoS  
防護

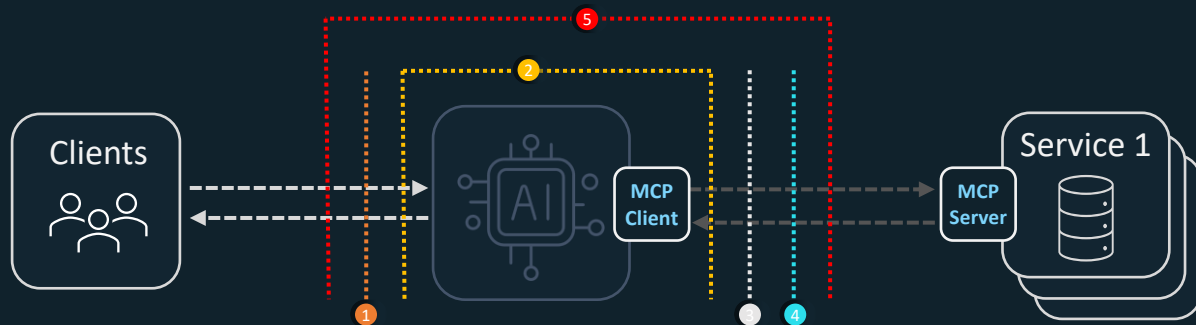
## 安全 擴充功能

LLM 防火牆

EAAF

威脅情資

# AI Agent 多層防護框架



## AI Guardrails

控制使用情況、驗證提示並防止注入或資料洩露

## 行為護欄

監控工具呼叫並阻止偏離目標的操作

## 安全代理存取

僅限授權代理進入系統

## 代理與工具分析

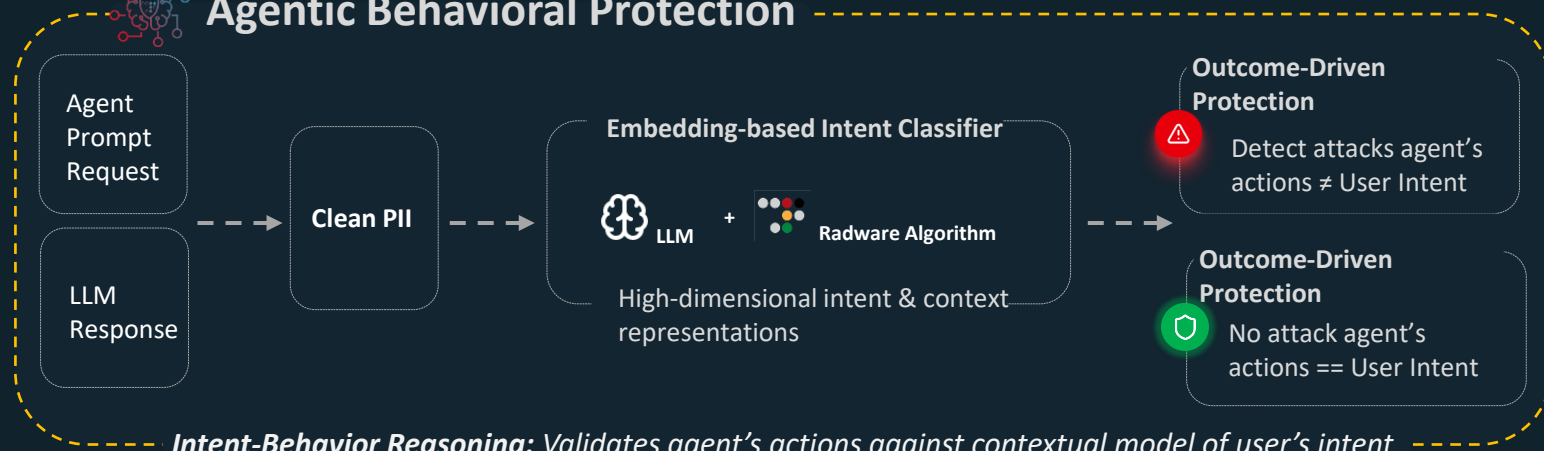
映射所有代理及其可存取的工具

## 操作分析

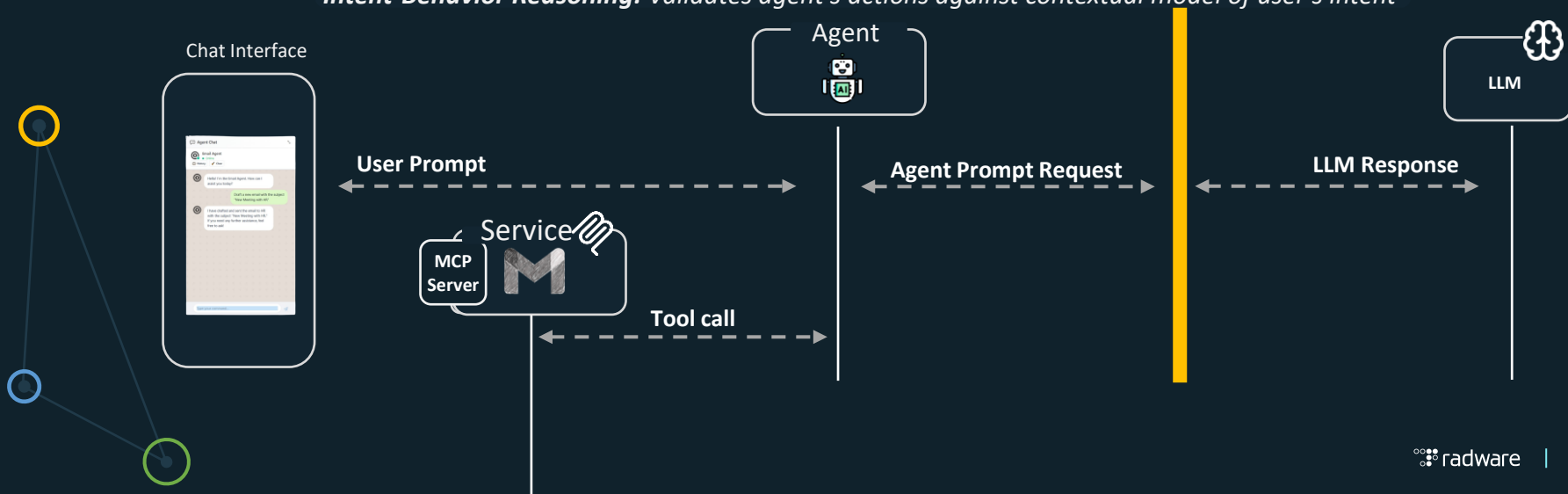
追蹤代理活動、模型使用和工具互動



# Agentic Behavioral Protection

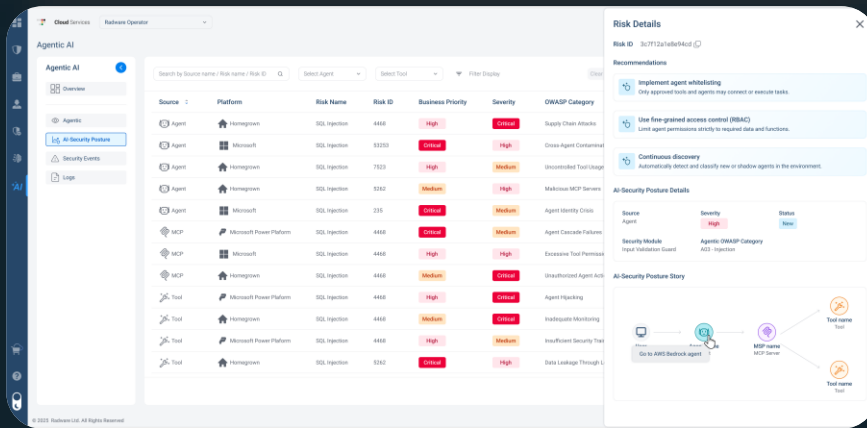
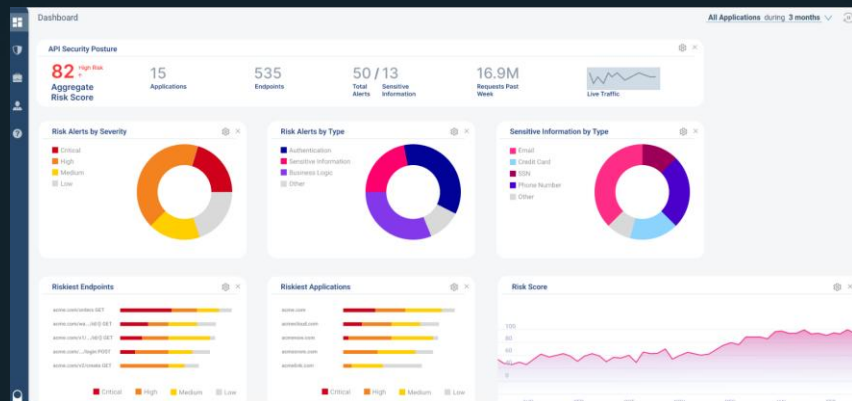


*Intent-Behavior Reasoning: Validates agent's actions against contextual model of user's intent*

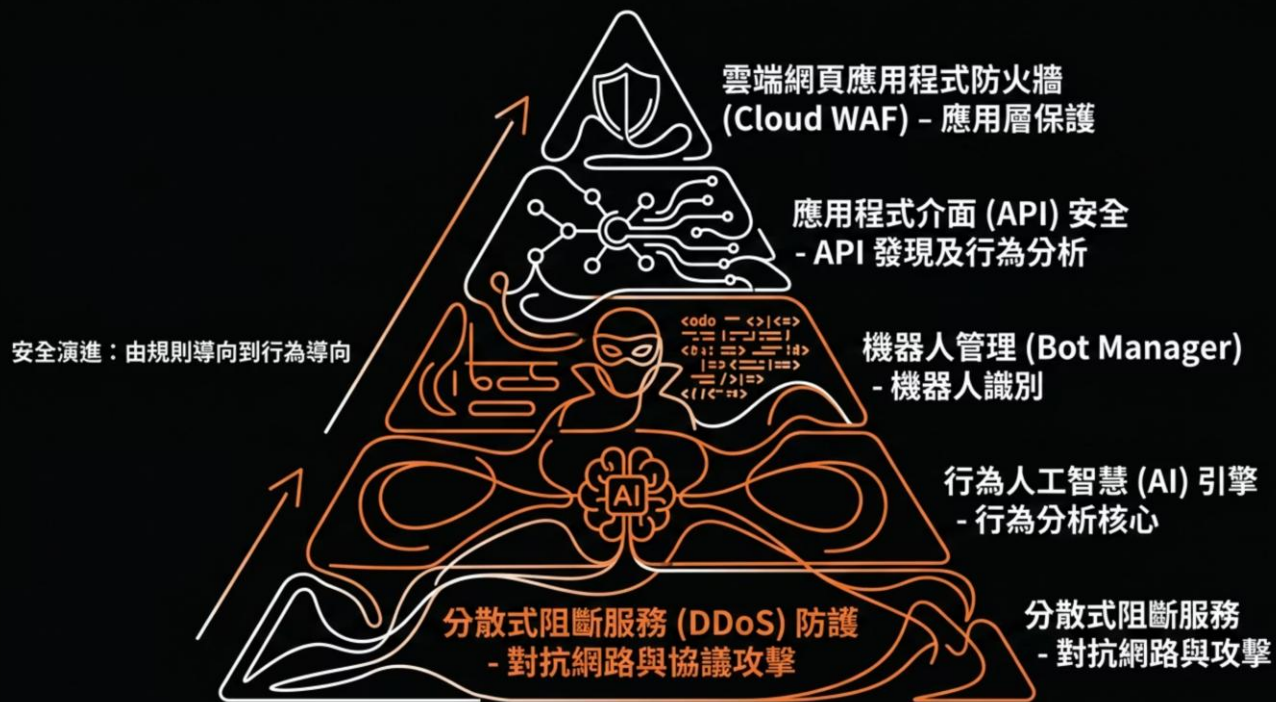


# 對 API 服務/AI Agent 進行持續合規性監控

- 檢測漏洞、錯誤配置和安全性策略是否一致
- 監控API/AI Agent流量:識別並評估跨代理商和工具的風險——涵蓋目標資料外洩、多代理風險流以及基於嚴重性的影響分析。
- 優先排序和修復: 根據即時威脅和攻擊者意圖進行動態優先排序
- Full Execution Risk Graph Mapping: 捕捉所有AI Agent環境中的完整代理工作流程，以明確風險來源。



Radware 提供完整的多層次防護架構，以 **Behavioral AI Engine 為核心**，  
從傳統 Rule-based 全面進化至 Behavior-based 動態防護模型。







# Today's Key Takeaways

面對 AI 帶來的雙重角色挑戰，企業需要重新審視 API 的治理框架。以下三個維度是構建 AI-Ready API 平台的核心支柱。

## 安全性與授權升級

傳統的 API Key 與 OAuth 機制需要延伸至 AI Agent 的身份識別與最小權限控管。針對 Machine Consumer 的行為異常偵測與速率限制策略必須重新設計。

## 可觀測性與 AI 流量治理

AI 呼叫產生的高頻、動態流量需要更細緻的追蹤與分析能力。建立 AI 專屬的 API 使用儀表板，區分人類流量與機器流量，才能有效管控成本與風險。

## AI Gateway/Guardrail 安全管理

建立 AI Gateway/Guardrail 作為企業所有 AI 服務的統一安全控管口，管理 LLM 呼叫、RAG 查詢與 Agent 工具存取，確保策略一致性與可維護性。